Universidad de Extremadura

Escuela Politécnica

Ingeniería Informática en Ingeniería del Software

Trabajo Fin de Grado

Desarrollo de una herramienta para la automatización de tareas de reconocimiento en auditorías de seguridad

David Gordillo Burrero

Convocatoria, 2025

Universidad de Extremadura

Escuela Politécnica

Ingeniería Informática en Ingeniería del Software

Trabajo Fin de Grado

Desarrollo de una herramienta para la automatización de tareas de reconocimiento en auditorías de seguridad

Autor: David Gordillo Burrero

Tutor: Tutor

Resumen

En el presente trabajo se ha desarrollado una herramienta orientada a la automatización de tareas fundamentales en auditorías de seguridad, con un enfoque específico en la fase de reconocimiento. Esta etapa, crítica en cualquier proceso de pentesting, abarca actividades como la recolección de información pasiva y activa, el escaneo de puertos y servicios, la enumeración de subdominios y tecnologías, así como la identificación preliminar de posibles vulnerabilidades.

La solución propuesta integra múltiples utilidades y técnicas ampliamente utilizadas en entornos profesionales de ciberseguridad (como Nmap, Feroxbuster, WhatWeb o WPScan), y se construye sobre una arquitectura modular y escalable que permite incorporar nuevas funcionalidades de forma sencilla en el futuro. A través de una interfaz web intuitiva, el usuario puede gestionar proyectos, ejecutar escaneos personalizados y consultar resultados de manera clara y estructurada.

Esta herramienta permite optimizar el flujo de trabajo durante las fases iniciales de una auditoría, automatizando tareas repetitivas, centralizando la información obtenida y reduciendo significativamente los tiempos de ejecución. Para ello, incorpora un sistema de inteligencia artificial basado en modelos generativos, que facilita la interacción con el contexto del escaneo para obtener recomendaciones específicas o definir próximos pasos según las debilidades detectadas. Además, genera automáticamente informes técnicos versionados, lo que simplifica la documentación del proceso y mejora su trazabilidad sin necesidad de intervención manual.

Palabras clave: Seguridad, Hacking Ético, Auditoría, Automatización, Herramienta.

Abstract

This project presents the development of a tool aimed at automating fundamental tasks in security audits, with a specific focus on the reconnaissance phase. This stage, which is critical in any penetration testing process, includes activities such as passive and active information gathering, port and service scanning, subdomain and technology enumeration, and the preliminary identification of potential vulnerabilities.

The proposed solution integrates several tools and techniques widely used in professional cybersecurity environments (such as Nmap, Feroxbuster, WhatWeb, or WPScan), and is built on a modular and scalable architecture that facilitates the future incorporation of new functionalities. Through an intuitive web interface, users can efficiently manage projects, execute customized scans, and review results in a clear and structured manner.

The tool helps optimize workflow during the initial stages of a security audit by automating repetitive tasks, centralizing collected data, and significantly reducing execution time. To achieve this, it includes an artificial intelligence system based on generative models, which allows users to interact with the scan context to receive specific recommendations or define next steps based on detected weaknesses. Additionally, it automatically generates versioned technical reports, streamlining the documentation process and improving traceability without requiring manual intervention.

Keywords: Security, Ethical Hacking, Auditing, Automation, Tool.

Índice general

1. Introducción **1**

1.1. Secciones 1

1.1.1. una subsección 2

1.1.2. otra subsección 2

1.2. Citas y referencias 2

1.3. Imágenes 2

1.4. Código 3

2. Objetivos **4**

3. Estado del Arte **5**

4. Metodología **6**

4.1. Escaneo de puertos y servicios 7

4.2. Enumeración de dominio 7

4.2.1. Reconocimiento DNS 7

4.2.2. OSINT de direcciones de correo electrónico 8

4.2.3. Enumeración de subdominios 8

4.3. Reconocimiento web 8

4.3.1. Escaneo de vulnerabilidades web 9

4.3.2. Detección de CMS 9

4.3.3. Captura de pantalla del sitio web 9

4.3.4. Enumeración de directorios y archivos 9

4.3.5. Reconocimiento de WordPress 9
4.3.6. Reconocimiento de Joomla 10
4.4. Enumeración del servicio FTP 10
4.5. Reconocimiento del servicio SSH 10
4.6. Generación de reportes 11
4.7. Funcionalidades adicionales 11

5. Implementación y desarrollo **13**

6. Resultados **14**

7. Conclusiones y trabajos futuros **15**

Anexos **16**

A. Ejemplo de anexo **17**
A.1. Sección de anexo 17

Bibliografía **18**

Índice de tablas

Índice de figuras

1.1. Logo EPCC 3

Capítulo 1

Introducción

Contenidos

1.1. Secciones **1**

1.1.1. una subsección 2

1.1.2. otra subsección 2

1.2. Citas y referencias **2**

1.3. Imágenes **2**

1.4. Código **3**

Esta plantilla sirve como ejemplo de TFE. Las secciones son las que están en la normativa, aunque si el tutor lo considera se puede cambiar la estructura. Esta sección la aprovechamos para introducir brevemente LaTeX.

1.1. Secciones

Las secciones se crean con *section*. Las subsecciones y subsubsecciones con *subsection* y *subsubsection*, respectivamente. Si se desea que alguna subsección en concreto no salga en el índice se pueden usar los mismos comandos añadiéndoles un asterisco al final (*subsection** y *subsubsection**).

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis. Curabitur dictum gravida mauris. Nam arcu libero, nonummy eget, consectetuer id, vulputate a, magna.

1.1.1. una subsección

Lorem ipsum dolor sit amet, consectetuer adipiscing elit.

1.1.2. otra subsección

Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis.

subsubsecciones

¡Por defecto las subsubsecciones no aparecen en el índice! Este comportamiento se puede cambiar, pero lo recomendable es organizar los capítulos en 3 niveles para facilitar la lectura.

1.2. Citas y referencias

Para citar un texto hay que incluirlo en el fichero *LocalBibliography.bib* de esta plantilla. Una vez hecho se puede referenciar usando el comando *cite* [1]. Para referenciar imágenes, secciones o tablas se usa el comando *autoref*. Por ejemplo Figura 1.1 o Capítulo 2.

Para facilitar la lectura, cuando se insertan citas y referencias es conveniente insertar un carácter de espacio sin salto de línea ˜ antes del comando de cita o referencia.

1.3. Imágenes

Las imágenes se insertan así:

Figura 1.1: Logo EPCC.
Fuente: https://politecnica.unex.es

1.4. Código

El código se puede insertar así:

```
echo "Este es un ejemplo de cómo se inserta código con la plantilla de Trabajo
↪  Fin de Estudios de la Escuela Politécnica de Cáceres"
```

También se puede seleccionar desde un fichero, por ejemplo:

Los lenguajes reconocidos para marcar se pueden consultar en https://pygments.org/docs/lexers/. Aunque depende del tipo de trabajo, se recomienda incluir código sólo en anexos.

Capítulo 2

Objetivos

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis. Curabitur dictum gravida mauris. Nam arcu libero, nonummy eget, consectetuer id, vulputate a, magna.

Capítulo 3

Estado del Arte

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis. Curabitur dictum gravida mauris. Nam arcu libero, nonummy eget, consectetuer id, vulputate a, magna.

Capítulo 4

Metodología

Contenidos

4.1. Escaneo de puertos y servicios 7

4.2. Enumeración de dominio 7

4.2.1. Reconocimiento DNS 7

4.2.2. OSINT de direcciones de correo electrónico 8

4.2.3. Enumeración de subdominios 8

4.3. Reconocimiento web 8

4.3.1. Escaneo de vulnerabilidades web 9

4.3.2. Detección de CMS 9

4.3.3. Captura de pantalla del sitio web 9

4.3.4. Enumeración de directorios y archivos 9

4.3.5. Reconocimiento de WordPress 9

4.3.6. Reconocimiento de Joomla 10

4.4. Enumeración del servicio FTP 10

4.5. Reconocimiento del servicio SSH 10

4.6. Generación de reportes 11

4.7. Funcionalidades adicionales 11

La herramienta implementada sigue un flujo de trabajo definido que automatiza de forma secuencial las tareas más relevantes en la fase de reconocimiento de una auditoría de seguridad. A continuación, se describen detalladamente cada una de las fases.

4.1. Escaneo de puertos y servicios

La primera fase consiste en la ejecución de un escaneo con `Nmap`, una herramienta ampliamente utilizada en entornos profesionales. Nmap permite identificar los puertos abiertos en el objetivo, los servicios que están corriendo sobre esos puertos y la versión específica de dichos servicios. Esta información resulta crítica para detectar superficies expuestas, planificar el resto del análisis y orientar futuras fases como la enumeración de vulnerabilidades o fuerza bruta de credenciales.

4.2. Enumeración de dominio

En caso de que el objetivo introducido sea un dominio (en lugar de una dirección IP), se activan tres módulos adicionales que permiten obtener información detallada sobre el mismo.

4.2.1. Reconocimiento DNS

Este módulo se encarga de realizar un reconocimiento pasivo del dominio, recopilando información pública y registros DNS. Se utilizan varias herramientas para llevar a cabo esta tarea:

- `dnsdumpster`: Se encarga de consultar y visualizar registros DNS del dominio, como `MX` (servidores de correo), `NS` (servidores de nombres) y `TXT` (configuraciones SPF, DKIM, etc).

- `mxtoolbox`: Se utiliza para consultar el registro `DMARC`, que proporciona mecanismos de protección ante ataques de suplantación de identidad vía correo electrónico.
- `API Ninja (WHOIS)`: Ejecuta consultas WHOIS para obtener información relacionada con la propiedad del dominio, fechas de creación y expiración, y otros datos relevantes.

4.2.2. OSINT de direcciones de correo electrónico

Tras el análisis DNS, se ejecuta un módulo de OSINT para obtener direcciones de correo electrónico asociadas al dominio, y verificar si estas han sido filtradas en alguna brecha de seguridad:

- `IntelligenceX`: Busca direcciones de correo filtradas asociadas al dominio en bases de datos públicas.
- `LeakCheck`: Comprueba si las direcciones encontradas han sido expuestas, en qué brechas concretas, y qué información fue filtrada. Esta herramienta fue elegida tras descartar alternativas como "Have I Been Pwned" o "DeHashed", que requerían suscripción o tenían limitaciones excesivas.

4.2.3. Enumeración de subdominios

Para ampliar la superficie de ataque, se ejecuta `Subfinder`, una herramienta que utiliza múltiples fuentes para obtener subdominios asociados al dominio objetivo. Posteriormente, se lanza `Httpx` para verificar cuáles de ellos están activos, comprobando su código de respuesta HTTP.

4.3. Reconocimiento web

Si se detecta que el puerto 80 está abierto, se lanzan una serie de modulos para realizar un reconocimiento exhaustivo del servicio web.

4.3.1. Escaneo de vulnerabilidades web

Se procede a escanear el objetivo con `Nuclei`, una herramienta moderna, flexible y en constante actualización. Permite identificar vulnerabilidades comunes y debilidades en aplicaciones web. Si el usuario activa el modo de *escaneo exhaustivo*, Nuclei se ejecutará también sobre todos los subdominios encontrados anteriormente.

4.3.2. Detección de CMS

Se utiliza `WhatWeb` para identificar si el sitio web analizado utiliza un gestor de contenidos (CMS) como WordPress o Joomla. Esta detección permite habilitar fases específicas posteriores, optimizadas para cada plataforma.

4.3.3. Captura de pantalla del sitio web

Para documentar visualmente el estado del objetivo, se emplea la librería `pyppeteer`, que interactúa con el navegador "headless" de Chrome para tomar una captura del sitio web. Esta imagen se incluye en el informe final.

4.3.4. Enumeración de directorios y archivos

En esta fase se utiliza `Feroxbuster`, una herramienta moderna con alto rendimiento, recursividad automática y gran capacidad de gestión de respuestas HTTP. Permite enumerar rutas y archivos ocultos que puedan resultar de interés para el auditor. Si se activa el modo de escaneo exhaustivo, la herramienta realiza una recursividad de nivel 2, enumerando directorios dentro de otros.

4.3.5. Reconocimiento de WordPress

Si el CMS detectado es WordPress, se lanza `WPScan` para enumerar:

- Usuarios del sitio, que se almacenan en una wordlist para fases posteriores.

- Plugins instalados, que se cruzan con bases de datos públicas para buscar CVEs. Si existe un exploit público en GitHub, se clona automáticamente.

En caso de disponer de usuarios enumerados, se lanza un ataque de fuerza bruta mediante `WPScan`, apuntando al recurso `xmlrpc.php`, que permite realizar múltiples intentos de autenticación sin restricciones. Si no se encontraron usuarios, se utiliza una wordlist por defecto con credenciales comunes.

4.3.6. Reconocimiento de Joomla

Si se detecta Joomla como CMS, se ejecuta `Joomscan`, que analiza vulnerabilidades conocidas, archivos de configuración expuestos, copias de seguridad accesibles, y posibles fallos asociados a versiones antiguas del sistema.

4.4. Enumeración del servicio FTP

Si el puerto 21 (FTP) está abierto, se utiliza la librería `ftplib` para interactuar con el servicio. Se comprueba:

- Si permite login anónimo.
- Si existen credenciales válidas (mediante fuerza bruta).
- Si se obtienen permisos de lectura/escritura.
- Se descarga el contenido del servidor y se analiza con `Searchsploit` por si existen vulnerabilidades relacionadas con la versión del servicio.

4.5. Reconocimiento del servicio SSH

Si el puerto 22 está abierto, se lanza un ataque de fuerza bruta con `Hydra`. Inicialmente se consideró la librería `paramiko`, pero fue descartada por no estar diseñada para este propósito. Se utilizan las mismas wordlists generadas anteriormente si existen usuarios.

Además, se analiza la versión del servicio con `Searchsploit` para comprobar posibles vulnerabilidades conocidas.

4.6. Generación de reportes

Una vez finalizado el análisis, la herramienta genera un informe en formato PDF con toda la información recopilada, organizada de forma clara y estructurada. Si el escaneo se ha realizado dentro de un proyecto, el informe se versiona automáticamente, permitiendo mantener un historial completo de auditorías sobre el mismo objetivo.

4.7. Funcionalidades adicionales

- **Asistente de IA**: El sistema integra un modelo generativo (Gemini) que permite al usuario consultar recomendaciones, próximos pasos, análisis de resultados o dudas específicas basadas en el escaneo realizado.
- **Generación de siguientes pasos con IA**: A partir de los resultados obtenidos, el modelo generativo sugiere los próximos pasos a seguir, facilitando la planificación de la auditoría.
- **Sugerencias de soluciones con IA**: El modelo generativo ofrece recomendaciones sobre posibles soluciones a las vulnerabilidades detectadas.
- **Modo de escaneo exhaustivo**: Amplía la profundidad del análisis activando opciones avanzadas en varias fases. Proporciona más información, aunque incrementa el tiempo total del escaneo.
- **Configuración de proxy**: El usuario puede configurar manualmente un proxy desde la interfaz gráfica, útil para evadir bloqueos y especialmente integrado con herramientas como `WPScan`.
- **Sistema de gestión de proyectos**: Desde la interfaz, el usuario puede crear y gestionar proyectos, permitiendo mantener informes versionados, comparar

resultados y documentar la evolución del objetivo.

- **Programación de escaneos**: La herramienta permite programar escaneos automáticos a horas específicas, facilitando la planificación y ejecución de auditorías.

Capítulo 5

Implementación y desarrollo

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis. Curabitur dictum gravida mauris. Nam arcu libero, nonummy eget, consectetuer id, vulputate a, magna.

Capítulo 6

Resultados

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis. Curabitur dictum gravida mauris. Nam arcu libero, nonummy eget, consectetuer id, vulputate a, magna.

Capítulo 7

Conclusiones y trabajos futuros

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis. Curabitur dictum gravida mauris. Nam arcu libero, nonummy eget, consectetuer id, vulputate a, magna.

Anexos

Anexo A

Ejemplo de anexo

Contenidos

A.1. Sección de anexo 17

Si no se desea incluir anexos, sólo hay que borrar este capítulo.

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis. Curabitur dictum gravida mauris. Nam arcu libero, nonummy eget, consectetuer id, vulputate a, magna.

A.1. Sección de anexo

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis. Curabitur dictum gravida mauris. Nam arcu libero, nonummy eget, consectetuer id, vulputate a, magna.

Bibliografía

[1] Claudio Vellage. LaTeX tutorials, 2017. URL: https://www.latex-tutorial.com/tutorials/ [cited 2017-04-05].